

# SEC-AC-004 - Access Control and Evidence Policy

Synthetic approved policy for Project Nova workshop use.

| Author                 | Version | Effective Date | Status   |
|------------------------|---------|----------------|----------|
| Nina Patel, Compliance | 4.2     | 01 Jul 2026    | Approved |

**AUTHORITATIVE SOURCE**

This policy supersedes the legacy three-year retention statement in the current-process document.

## 1. Scope

This policy applies to employee and contractor access decisions for internal business applications, including approved, rejected, changed and revoked access where the retention interpretation is confirmed.

## 2. Approval controls

- Standard access requires line-manager approval and any application-specific approval defined by the application owner.
- Privileged access requires application-owner approval and Security approval.
- A requester or fulfiller must not approve their own privileged access.
- MFA is mandatory for privileged interactive access.
- AI-generated recommendations must not be treated as access approval.

## 3. Session controls

| Access Type                   | Maximum Session Duration | Authority                                            |
|-------------------------------|--------------------------|------------------------------------------------------|
| Privileged interactive access | 15 minutes               | Mandatory policy control                             |
| Standard interactive access   | Up to 30 minutes         | Permitted; product owner confirms the selected value |
| Service accounts              | Not defined here         | Separate non-interactive control standard            |

## 4. Evidence requirements

- requester and access subject;
- worker type and manager;
- application and requested access level;
- business reason;
- approvers and timestamped decisions;
- fulfilment and revocation evidence;
- exceptions and compensating controls.

## 5. Retention

**APPROVED RETENTION**

Retain access-decision evidence for seven years from the final decision or revocation, whichever is later.

The application of the seven-year period to rejected requests requires Legal confirmation. Until confirmed, rejected requests must remain in the conflict/open-question register and must not be deleted based on the obsolete three-year instruction.

## 6. Source and review

| Field       | Value                                                  |
|-------------|--------------------------------------------------------|
| Policy ID   | SEC-AC-004                                             |
| Approver    | Chief Information Security Officer                     |
| Next review | 01 Jul 2027                                            |
| Supersedes  | SEC-AC-004 v3.6 and local three-year work instructions |

**WORKSHOP NOTICE**

All people, systems and policy identifiers are fictional and created for training.